

Modelo de Encuesta Integral VAST Nacional – España

Versión 1.0 – Abril 2026

Este cuestionario está dirigido a responsables de ciberseguridad, tecnología, riesgo y continuidad de negocio de organizaciones españolas, especialmente operadores de servicios esenciales, infraestructuras críticas y entidades de alto impacto sectorial.

Tranquilidad: no hay respuestas “buenas” o “malas”; solo radiografías más o menos optimistas.

1. Información general de la organización

1.1. Tipo de organización

Seleccione la opción que mejor describa su organización (una única respuesta):

- ☐ Administración pública – estatal
- ☐ Administración pública – autonómica
- ☐ Administración pública – local
- ☐ Operador de servicios esenciales (NIS2) – Energía
- ☐ Operador de servicios esenciales – Agua
- ☐ Operador de servicios esenciales – Sanidad
- ☐ Operador de servicios esenciales – Transporte
- ☐ Sector financiero / asegurador
- ☐ Telecomunicaciones / servicios digitales
- ☐ Industria / manufactura
- ☐ Educación / I+D
- ☐ Otro (especificar): _____

1.2. Tamaño de la organización

- ☐ Micro (menos de 10 empleados)
- ☐ Pequeña (10–49 empleados)
- ☐ Mediana (50–249 empleados)
- ☐ Grande (250–999 empleados)
- ☐ Muy grande (≥ 1.000 empleados)

1.3. Rol de la persona que responde

- ☐ CISO / Director de Seguridad de la Información
- ☐ CIO / Director de Sistemas / TI
- ☐ CTO / Director de Tecnología
- ☐ Responsable de Riesgos / CRO
- ☐ Responsable de Continuidad de Negocio / Resiliencia
- ☐ Responsable de Cumplimiento / Legal
- ☐ Otro (especificar): _____

2. Gobernanza y estrategia de ciberseguridad

2.1. Estrategia y planes

P1. ¿Dispone su organización de una estrategia formal de ciberseguridad aprobada por la alta dirección?

- ☐ Sí, formalmente aprobada y vigente, con revisión al menos anual
- ☐ Sí, formalmente aprobada, pero sin revisiones recientes
- ☐ Existe un borrador o marco informal, no aprobado formalmente
- ☐ No disponemos de estrategia formal
- ☐ No sabe / no responde

P2. ¿Dispone su organización de un plan de acción (hoja de ruta) con objetivos, hitos y métricas de ciberseguridad?

- ☐ Sí, con objetivos cuantificados y plazos definidos
- ☐ Sí, pero los objetivos son mayoritariamente cualitativos
- ☐ Existe un conjunto de iniciativas sin una planificación estructurada
- ☐ No disponemos de plan de acción específico
- ☐ No sabe / no responde

2.2. Marco normativo y alineamiento

P3. ¿Con qué marcos normativos y de referencia se alinea su organización? (puede marcar varias opciones)

- ☐ NIS2 / normativa nacional de transposición
- ☐ DORA (entidades financieras / servicios TIC críticos)
- ☐ Esquema Nacional de Seguridad (ENS)
- ☐ ISO/IEC 27001 / 27002
- ☐ NIST Cybersecurity Framework (CSF)
- ☐ MARCO propio de grupo / corporativo internacional
- ☐ Otros (especificar): _____

P4. En una escala de 1 a 5, ¿cómo valoraría el grado de cumplimiento de su organización con los requisitos regulatorios aplicables?

- ☐ 1 – Muy inicial: conocemos los requisitos, pero el cumplimiento es limitado
- ☐ 2 – Básico: cumplimos con lo mínimo imprescindible
- ☐ 3 – Intermedio: la mayoría de requisitos se cumplen de forma estable
- ☐ 4 – Avanzado: cumplimiento sólido, con revisión periódica y evidencias
- ☐ 5 – Excelente: además de cumplir, aplicamos buenas prácticas adicionales

3. Inventario de activos y superficie de ataque

3.1. Inventario y clasificación

P5. ¿Dispone su organización de un inventario actualizado de activos de información (aplicaciones, sistemas, datos, servicios en nube, etc.)?

- ☐ Sí, centralizado y actualizado automáticamente
- ☐ Sí, centralizado pero con actualización manual
- ☐ Existente, pero parcial y no sistemático
- ☐ No disponemos de inventario formal
- ☐ No sabe / no responde

P6. ¿Clasifica su organización los activos según criticidad para el negocio (por ejemplo: crítico, alto, medio, bajo)?

- ☐ Sí, con criterios documentados y aplicados consistentemente
- ☐ Sí, pero los criterios no están formalmente documentados
- ☐ Solo en algunos sistemas o proyectos
- ☐ No clasificamos los activos
- ☐ No sabe / no responde

3.2. Visibilidad de la superficie de ataque

P7. ¿Dispone su organización de herramientas de descubrimiento y monitorización de superficie de ataque (incluyendo activos expuestos a Internet y en la nube)?

- ☐ Sí, con cobertura amplia y revisiones periódicas
- ☐ Sí, pero centradas solo en activos de TI tradicionales
- ☐ En fase piloto / proyecto
- ☐ No disponemos de herramientas específicas
- ☐ No sabe / no responde

P8. ¿Con qué frecuencia revisa su organización la lista de activos críticos y expuestos?

- ☐ Mensualmente o con mayor frecuencia
- ☐ Trimestralmente
- ☐ Anualmente
- ☐ Menos de una vez al año / no hay revisión planificada
- ☐ No sabe / no responde

4. Modelado de amenazas (enfoque VAST y similares)

4.1. Adopción de modelado de amenazas

P9. ¿Realiza su organización modelado de amenazas para aplicaciones, sistemas y procesos críticos?

- ☐ Sí, de forma sistemática y documentada en la mayoría de sistemas críticos
- ☐ Sí, pero solo en proyectos de alta visibilidad o nuevos desarrollos
- ☐ En fase piloto o experimental
- ☐ Conocemos la técnica, pero no la aplicamos
- ☐ No conocemos ni aplicamos modelado de amenazas

P10. ¿Qué metodologías de modelado de amenazas utiliza su organización? (marque todas las que apliquen)

- ☐ VAST (Visual, Agile, Simple Threat)
- ☐ STRIDE u otras metodologías de Microsoft / similares
- ☐ PASTA u otros enfoques basados en riesgo
- ☐ Metodología interna propia
- ☐ Otro (especificar): ____
- ☐ No se utiliza ninguna metodología formal

4.2. Alcance y frecuencia

P11. Aproximadamente, ¿qué porcentaje de sus aplicaciones críticas cuentan con un modelo de amenazas formalmente documentado?

- ☐ 0 % – Ninguna
- ☐ 1-25 % – Una minoría
- ☐ 26-50 % – Una parte significativa
- ☐ 51-75 % – La mayoría
- ☐ 76-100 % – Casi todas o todas
- ☐ No sabe / no responde

P12. ¿Con qué frecuencia se revisan y actualizan los modelos de amenazas?

- ☐ En cada cambio significativo de arquitectura o funcionalidad
- ☐ Periódicamente (al menos una vez al año)
- ☐ Solo ante cambios mayores o auditorías
- ☐ No se revisan; se crean una vez y permanecen estáticos
- ☐ No sabe / no responde

4.3. Automatización, integración y colaboración

P13. ¿Se integran las actividades de modelado de amenazas en el ciclo de vida de desarrollo (SDLC) y en los pipelines CI/CD?

- ☐ Sí, automatizadas en los pipelines (CI/CD) con validaciones de seguridad
- ☐ Sí, integradas en el proceso de desarrollo aunque sin automatización
- ☐ Parcialmente, solo en proyectos específicos
- ☐ No están integradas; se realizan de forma puntual y aislada
- ☐ No aplica / no sabe

P14. ¿Quién participa habitualmente en las sesiones de modelado de amenazas? (marque todas las que apliquen)

- ☐ Desarrollo / Ingeniería
- ☐ Operaciones / Infraestructura
- ☐ Seguridad de la información / CISO
- ☐ Arquitectura de TI
- ☐ Negocio / responsables de procesos
- ☐ Proveedores externos
- ☐ Otros (especificar): _____

P15. ¿Cómo se comunican los resultados del modelado de amenazas?

- ☐ Informes técnicos detallados orientados a equipos de TI
- ☐ Informes ejecutivos con lenguaje de riesgo y negocio
- ☐ Paneles / dashboards integrados en herramientas de gestión
- ☐ Emails / documentos ad hoc sin formato estándar
- ☐ No existe un mecanismo de comunicación definido

5. Indicadores y métricas de ciberseguridad

5.1. Métricas operativas y técnicas

P16. ¿Qué tipo de métricas técnicas de ciberseguridad monitoriza regularmente su organización? (marque todas las que apliquen)

- ☐ Número de vulnerabilidades por criticidad (baja, media, alta, crítica)
- ☐ Tiempo medio de detección de incidentes (MTTD)
- ☐ Tiempo medio de respuesta y recuperación (MTTR)
- ☐ Número de incidentes significativos por periodo
- ☐ Porcentaje de sistemas con parches al día
- ☐ Otras (especificar): _____
- ☐ No se monitorizan métricas técnicas de forma sistemática

P17. ¿Dispone su organización de objetivos formales (SLAs / SLOs) para tiempos de detección y respuesta?

- ☐ Sí, definidos, aprobados y monitorizados
- ☐ Sí, definidos pero no se monitorizan sistemáticamente
- ☐ Se aplican objetivos informales o “de buena voluntad”
- ☐ No existen objetivos definidos
- ☐ No sabe / no responde

5.2. Métricas de riesgo y negocio

P18. ¿Cuantifica su organización la exposición al riesgo de ciberseguridad en términos económicos (por ejemplo, pérdidas esperadas, VaR, escenarios de impacto)?

- ☐ Sí, mediante modelos cuantitativos formales
- ☐ Sí, mediante estimaciones semicuantitativas (rangos, escalas)
- ☐ Solo de forma cualitativa (alto, medio, bajo)
- ☐ No se cuantifica la exposición en términos económicos
- ☐ No sabe / no responde

P19. ¿Se reportan indicadores de ciberseguridad al Consejo de Administración o máximo órgano de gobierno?

- ☐ Sí, con periodicidad al menos trimestral
- ☐ Sí, pero con periodicidad irregular
- ☐ Solo en caso de incidentes graves
- ☐ No se reportan indicadores específicos
- ☐ No sabe / no responde

P20. ¿Qué indicadores de alto nivel se reportan habitualmente a la alta dirección? (marque todas las que apliquen)

- ☐ Número y gravedad de incidentes
- ☐ Nivel de cumplimiento normativo (NIS2, ENS, ISO, etc.)
- ☐ Riesgo residual por dominios (identidad, red, aplicaciones, datos, terceros)
- ☐ Grado de ejecución del plan de acción de ciberseguridad
- ☐ Pérdidas económicas asociadas a incidentes
- ☐ Otros (especificar): ____
- ☐ No se reportan indicadores a la alta dirección

6. Vulnerabilidades, exposición y terceros

6.1. Gestión de vulnerabilidades

P21. ¿Qué herramientas utiliza para la gestión de vulnerabilidades? (respuesta múltiple)

- ☐ Soluciones comerciales de escaneo de vulnerabilidades de infraestructura
- ☐ Soluciones SCA / SAST / DAST para aplicaciones
- ☐ Herramientas de gestión de parches
- ☐ Herramientas de scoring de riesgo (p. ej. VPR, ACR, similares)
- ☐ Herramientas desarrolladas internamente
- ☐ No utilizamos herramientas específicas

P22. ¿Cuál es el tiempo medio de remediación de vulnerabilidades críticas en sistemas clave?

- ☐ Menos de 7 días
- ☐ Entre 7 y 30 días
- ☐ Entre 31 y 90 días
- ☐ Más de 90 días
- ☐ No se mide / no sabe

P23. ¿Monitoriza su organización vulnerabilidades explotadas activamente (por ejemplo, vía fuentes oficiales o proveedores) y les da prioridad especial?

- ☐ Sí, con procesos y criterios formales
- ☐ Sí, pero de forma informal y ad hoc
- ☐ No de manera sistemática
- ☐ No sabe / no responde

6.2. Terceros y cadena de suministro

P24. ¿Dispone su organización de un proceso formal de evaluación de riesgos de ciberseguridad para proveedores y terceros?

- ☐ Sí, con criterios definidos y evaluaciones periódicas
- ☐ Sí, pero se aplica solo a algunos proveedores críticos
- ☐ En fase de diseño / implantación
- ☐ No disponemos de proceso formal
- ☐ No sabe / no responde

P25. ¿Incluye el modelado de amenazas y la evaluación de ciber riesgos a terceros en los contratos y acuerdos de nivel de servicio (SLAs)?

- ☐ Sí, de forma sistemática
- ☐ Sí, pero solo en algunos contratos estratégicos
- ☐ Ocasionalmente, según la sensibilidad del servicio
- ☐ No se incluye este tipo de cláusulas
- ☐ No sabe / no responde

7. Respuesta a incidentes, continuidad y resiliencia

7.1. Preparación y respuesta

P26. ¿Dispone su organización de un plan de respuesta a incidentes de ciberseguridad formalmente aprobado?

- ☐ Sí, y se prueba mediante simulacros al menos una vez al año
- ☐ Sí, pero con pruebas esporádicas o inexistentes
- ☐ En fase de elaboración
- ☐ No disponemos de plan formal
- ☐ No sabe / no responde

P27. ¿Dispone de procedimientos para notificar incidentes a autoridades competentes (p. ej. CNC, CCN-CERT, supervisores sectoriales) según la normativa aplicable?

- ☐ Sí, documentados y probados
- ☐ Sí, documentados pero no probados
- ☐ Procedimientos informales basados en “buena voluntad”
- ☐ No existen procedimientos definidos
- ☐ No sabe / no responde

7.2. Continuidad de negocio y recuperación

P28. ¿Dispone su organización de planes de continuidad de negocio (BCP) y recuperación ante desastres (DRP) que contemplen ciberincidentes?

- ☐ Sí, y se realizan pruebas y simulacros periódicos
- ☐ Sí, pero sin pruebas regulares
- ☐ En elaboración o revisión
- ☐ No disponemos de BCP/DRP específicos
- ☐ No sabe / no responde

P29. ¿Se han definido objetivos de tiempo de recuperación (RTO) y punto de recuperación (RPO) para sistemas críticos?

- ☐ Sí, definidos, aprobados y alineados con negocio
- ☐ Sí, pero no están formalmente aprobados
- ☐ Solo parámetros técnicos, sin consenso con negocio
- ☐ No se han definido RTO/RPO
- ☐ No sabe / no responde

8. Talento, cultura y formación

8.1. Recursos y capacidades

P30. ¿Cómo describiría la dotación de personal especializado en ciberseguridad en su organización?

- ☐ Ampliamente suficiente para las necesidades actuales
- ☐ Razonablemente adecuada, con algunas áreas tensionadas
- ☐ Clara insuficiencia de recursos
- ☐ Dependencia significativa de proveedores externos
- ☐ No sabe / no responde

P31. ¿Tiene dificultades para cubrir posiciones de ciberseguridad?

- ☐ Sí, de forma recurrente
- ☐ Ocasionalmente
- ☐ No, cubrimos vacantes con relativa facilidad
- ☐ No aplica (no incorporamos perfiles específicos)
- ☐ No sabe / no responde

8.2. Concienciación y cultura

P32. ¿Realiza su organización programas de concienciación en ciberseguridad para el conjunto de empleados?

- ☐ Sí, con programas estructurados y recurrentes
- ☐ Sí, pero de forma esporádica o reactiva
- ☐ Solo para colectivos muy específicos
- ☐ No se realizan programas de concienciación
- ☐ No sabe / no responde

P33. ¿Incluye el modelado de amenazas y la “mentalidad de adversario” en la formación de equipos técnicos?

- ☐ Sí, con formación específica y práctica
- ☐ Sí, pero solo de manera introductoria
- ☐ En planes futuros
- ☐ No se contempla este tipo de formación
- ☐ No sabe / no responde

9. Visión de futuro y prioridades

9.1. Prioridades de inversión

P34. ¿Cuáles son las principales prioridades de inversión en ciberseguridad de su organización para los próximos 2 años? (marque hasta 3)

- ☐ Refuerzo de capacidades de detección y respuesta (SOC, SIEM, EDR/XDR)
- ☐ Mejora de la resiliencia y continuidad (backups, DR, redundancias)
- ☐ Refuerzo de la seguridad en la nube y entornos híbridos
- ☐ Gestión de identidades y accesos (IAM, PAM, Zero Trust)
- ☐ Modelado de amenazas y seguridad en el ciclo de desarrollo (DevSecOps)
- ☐ Gestión de terceros y cadena de suministro
- ☐ Automatización y orquestación de seguridad
- ☐ Talento, formación y cultura
- ☐ Otros (especificar): _____

9.2. Perspectiva sobre modelado de amenazas

P35. En relación con el modelado de amenazas (incluyendo enfoques como VAST), su organización:

- ☐ Lo considera una práctica esencial y continuará reforzándolo
- ☐ Lo ve útil, pero secundario frente a otras prioridades
- ☐ Lo percibe como una carga adicional poco justificada
- ☐ Aún no ha formado una opinión clara
- ☐ No conoce suficientemente la práctica como para opinar

P36. ¿Estaría interesado en participar en iniciativas sectoriales o nacionales para compartir buenas prácticas y métricas de modelado de amenazas?

- ☐ Sí, de forma activa
- ☐ Sí, puntualmente
- ☐ Quizá, dependiendo de la carga y el retorno percibido
- ☐ No, preferimos mantener la gestión internamente
- ☐ No sabe / no responde

10. Comentarios finales

P37. Comentarios adicionales (opcional)

Utilice este espacio para compartir cualquier reflexión, comentario o sugerencia sobre el enfoque de modelado de amenazas, métricas de ciberseguridad y la situación general de su organización:

Gracias por dedicar tiempo a esta encuesta. Su sinceridad ayudará a que las estadísticas sean más útiles que un informe complaciente y menos aburridas que un manual de compliance.